

****SEE ALSO:**** Newsletter of February 14, 2024

[doc. web n. 9983244]

Provision of January 11, 2024

Register of provisions

n. 11 of January 11, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by

Dr. Giuseppe Stanzione, president, Dr.

Guido Scorza, vice president, Dr. Agostino

Ghiglia and Prof. Ginevra Cerrina Feroni,

members, and Mr. Fabio Mattei, general secretary;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament

and of the Council, of April 27, 2016, concerning

the protection of natural persons with regard to

the processing of personal data, as well as the free

movement of such data and repealing Directive

95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing

"Code regarding the protection of personal data,

containing provisions for the adaptation

of the national legal system to Regulation (EU)

2016/679 of the European Parliament and of the Council, of

April 27, 2016, concerning the protection of

natural persons with regard to the processing of personal data,

as well as the free movement of such data and repealing Directive 95/46/EC (hereinafter

"Code");

HAVING REGARD TO Regulation No. 1/2019 concerning

internal procedures with external relevance,

aimed at carrying out the tasks and

exercising the powers assigned to the Guarantor for the

protection of personal data, approved by

resolution No. 98 of 04/04/2019, published in

G.U. No. 106 of 08/05/2019 and on www.gpdp.it, doc. web

n. 9107633 (hereinafter "Guarantor Regulation No. 1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the General

Secretary pursuant to Article 15 of the Guarantor Regulation No. 1/2000 on the

organization and functioning of the office of the Guarantor for the

protection of personal data, on www.gpdp.it, doc.

web n. 1098801;

Reporting by Dr. Guido Scorza;

PREMISE

1. The report

With a note dated XX, the XX communicated to the Authority that it had acquired against Dr. Bagnato

"elements (...) that appeared non-compliant with the relevant regulations regarding the protection of

personal data" in relation to "a system for

prescribing medications, specialist visits, and medical certificates, in violation of the general principle

that establishes that

personal data must be processed in a manner that ensures adequate security, including protection, through appropriate organizational measures, against unauthorized or unlawful processing and accidental damage ('integrity and confidentiality')."

In the aforementioned communication from the XX, it was reported that it was possible to "ascertain that on the external wall of the Medical Office, next to the entrance door of the office and in its immediate vicinity, there were affixed a mailbox and a metal container, both lacking any name. However, the container bore the indication 'medical prescriptions only' while a key was inserted in the lock of the container. This container was also publicly accessible as, during the service, several people were seen opening it and taking out pieces of paper that were inside. Furthermore, it was located in the public square where there is free parking; in the same building and on the same level as the medical office, but with separate accesses, the AVIS headquarters and a blood collection center of the ASL of XX are also active."

The XX also reported that it was found that inside the container "numerous medical prescriptions were stored, most of which consisted of 'electronic prescription — reminder for the patient' and, for the remainder, 'pink prescriptions' taken from the SSN prescription book. The prescriptions had been filled out in favor of various names, some bore the doctor's signature (in the case of SSN prescriptions), and all were accessible to anyone since they (with one exception) were not even placed inside closed envelopes; there were 67 prescriptions in the container. A cursory examination of them revealed that the medical prescriptions had been issued in favor of different subjects and included prescriptions for both medications and specialist examinations."

While highlighting that the checks were "carried out during the period from 09.02.2023 to 04.04.2023," it was represented that "what was ascertained by the personnel of this Unit was confirmed by statements obtained from seven patients of Dr. Bagnato, some of whom were identified among those who were seen accessing the metal container" and that from the statements made "it emerged that the system described above had been implemented by Dr. XX Bagnato during the period when the noted Covid-19 issue was ongoing, and was then maintained even afterwards, after its cessation."

To the aforementioned communication, a document was attached bearing "Service Annotation regarding facts and circumstances that may constitute a report to the Guarantor for the Protection of Personal Data, ascertained during observation services carried out during the period from 09.02.2023 to 04.04.2023," as well as reproductions of photographic evidence, in support of what has been reported.

2. The Investigative Activity

Following a request for information made by the Authority, pursuant to Article 157 of the Code (note of XX, prot. no. XX), Dr. Bagnato provided a response with the note of XX, stating that:

- "the episodic and occasional nature of the reported matter is observed";
- "aware of the importance of processing the personal data of my patients, it is specified that the delivery of medical prescriptions through deposit in the metal container occurs only and exclusively for those patients who expressly request it, thereby consenting to a limitation of their own privacy. Indeed, the same report highlights that the prescriptions 'were accessible to anyone since they (with the exception of one case) were not even placed inside closed envelopes.' This circumstance is clear evidence that when the patient did not make an express request, the prescription was placed in a closed envelope to protect the integrity and confidentiality of their personal data";
- "this method of delivering prescriptions allows (...) to limit the number of patient accesses during office hours, preventing the patient from having to come to my office simply to collect the prescriptions, and at the same time allows for an easy way to access the service, being able to collect the prescriptions at any time of the day";
- "the metal container, equipped with a key and always closed, is placed in an area delineated to the public by red posts, accessible only to those with an interest, and not directly in the public square as reported in the notification";
- "the 'various' individuals who were seen by the inspecting agents opening the container all took 'sheets of paper' (the medical prescriptions) present inside it. This confirms that access to the container was made exclusively by my patients, who, I repeat, consented to the release of the prescriptions in that manner, and not by third parties";

- “in any case, I have already taken steps to remove the container that is the subject of the present dispute.”

With reference to what emerged from the examination of the documentation reviewed and the statements made, considering that the described conduct was found not to be in compliance with the relevant regulations regarding the protection of personal data, the Office, with act of XX (prot. no. XX), notified Dr. Bagnato, pursuant to Article 166, paragraph 5, of the Code, of the initiation of proceedings for the adoption of measures referred to in Article 58, paragraph 2, of the Regulation, inviting him to submit defensive writings or documents or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code, as well as Article 18, paragraph 1, Law No. 689 of November 24, 1981).

In particular, the Office, with the aforementioned act, deemed that Dr. Bagnato had carried out a processing of personal data in violation of the basic principles of data processing referred to in Articles 5 and 9 of the Regulation and the obligation regarding the security of processing, as per Article 32 of the Regulation as well as Article 2-septies, paragraph 8, of the Code.

Dr. Bagnato did not produce any defensive documents in this regard and did not request to be heard by the Authority.

3. Outcome of the Investigative Activity

Taking note of what was represented by the doctor during the proceedings, it is observed that:

- for “personal data” is meant “any information relating to an identified or identifiable natural person (‘data subject’)” and for “data concerning health” “personal data related to the physical or mental health of a natural person, including the provision of health care, which reveals information concerning his or her health status” (Article 4, paragraph 1, nos. 1 and 15 of the Regulation). The latter data deserve greater protection since the context of their processing could create significant risks for fundamental rights and freedoms (Recital No. 51 of the Regulation);
- the regulations on the protection of personal data provide that data controllers are required to comply with the applicable principles for data processing, among which is the principle of “integrity and confidentiality,” according to which personal data must be “processed in a manner that ensures adequate security (...), including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage” (Article 5, paragraph 1, letter f) of the Regulation). The data controller is required to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk presented by the processing resulting from unauthorized disclosure or accidental or unlawful access to personal data transmitted, stored or otherwise processed (Article 32 of the Regulation); in particular, in the health sector, the controller must adopt suitable measures to ensure, even in the organization of services and performances, respect for the rights, fundamental freedoms, and dignity of the data subjects (Article 83 of the Code - deemed compatible with the aforementioned Regulation (EU) No. 2016/679, see Article 22, paragraph 11, Legislative Decree of August 10, 2018, No. 101 - in relation to which the Authority has adopted a specific general provision - see provision of November 9, 2005, available at www.garanteprivacy.it, web doc no. 1191411 - see Article 22, paragraph 4, of the aforementioned Legislative Decree No. 101/2018);
- health-related information can be of such measures.”

The violation of Articles 5, 9, and 32 of the Regulation, as well as Article 2-septies, paragraph 8, of the Code, resulting from the processing of personal data, which is the subject of this provision, carried out by Dr. Bagnato, is subject to the application of an administrative monetary penalty pursuant to Article 83, paragraphs 4 and 5 of the Regulation.

It should be noted that the Authority, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to “impose an administrative monetary penalty pursuant to Article 83, in addition to [other] [corrective] measures referred to in this paragraph, or in lieu of such measures.”

of such measures, depending on the circumstances of each individual case” and, in this context, “the College [of the Authority] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Authority's website

pursuant to Article 166, paragraph 7, of the Code” (Article 16, paragraph 1, of the Authority Regulation No. 1/2019).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation, in light of the elements provided for in Article 83, paragraph 2, of the Regulation, with particular reference to which it is observed that:

- the processing of data involved information regarding the health status of a large number of patients of Dr. Bagnato and had a confirmed duration of two months (Article 83, paragraph 2, letters a) and g) of the Regulation);
- the violation and the degree of responsibility of the data controller is high (Article 83, paragraph 2, letters b) and d) of the Regulation);
- the report was made by XX also based on statements made by patients regarding the conduct of Dr. Bagnato (Article 83, paragraph 2, letter k) of the Regulation);
- the doctor did not demonstrate full cooperation with the Authority during the investigation procedure, having provided a brief response to the request for information made by the Authority; moreover, he also failed to produce defensive writings or documents in relation to the notification, pursuant to Article 166, paragraph 5, of the Code, of the initiation of the procedure for the adoption of the measures referred to in Article 58, paragraph 2, of the Regulation, in order to substantiate what was initially claimed.

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the pecuniary sanction at €20,000.00 for the violation of Articles 5, 9, and 32 of the Regulation, as well as Article 2-septies, paragraph 8 of the Code, as an administrative pecuniary sanction considered, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and deterrent.

It is also considered that the accessory sanction of publication on the Authority's website of this provision, provided for by Article 166, paragraph 7, of the Code and Article 16 of the Authority Regulation No. 1/2019, should be applied, in relation to the particular category of personal data processed and the number of affected individuals involved.

Finally, it is noted that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

ALL OF THE ABOVE CONSIDERED, THE AUTHORITY

having noted the violation of Articles 5, 9, and 32 of the Regulation as well as Article 2-septies, paragraph 8 of the Code, declares the unlawfulness of the processing of personal data carried out by Dr. Bagnato as stated in the reasoning;

ORDERS

Dr. XX Bagnato, born in XX (XX) on XX, Tax Code XX, residing in XX (XX), XX, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, to pay the sum of €20,000.00 (twenty thousand) as an administrative pecuniary sanction for the violation referred to in this provision, according to the methods indicated in the attachment, within 30 days from the notification of the reasoning; it is noted that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by paying, within the 30-day period, an amount equal to half of the imposed sanction;

ORDERS

the aforementioned Dr. Bagnato, in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €20,000.00 (twenty thousand), according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of subsequent enforcement acts pursuant to Article 27 of Law No. 689/1981;

DISPOSES

- the publication of this provision on the Authority's website, pursuant to Article 166, paragraph 7, of the Code;
- the annotation of this provision in the internal register of the Authority - provided for by Article 57, paragraph 1, letter u), of the Regulation, as well as by Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority - relating to the violations and measures adopted in accordance with Article 58, paragraph 2, of the same Regulation.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, January 11, 2024

THE PRESIDENT

Stanzione

THE RAPPORTEUR

Scorza

THE SECRETARY GENERAL

Mattei